

EO 14117 风险评估结论报告（草案）

输入摘要

```
{
  "project_name": "EO14117评估—位置数据供应商协议",
  "transaction_description":
    "通过供应商协议向中国AI公司提供150,000名美国人的精确地理位置数据用于算法训练",
  "transaction_type": "vendor_agreement",
  "data_items": [
    {
      "data_item_name": "精确GPS轨迹数据",
      "data_description": "150,000名美国人的实时GPS轨迹数据，精度<10米",
      "business_context": "AI模型训练——位置预测算法",
      "is_personal_info": true,
      "is_sensitive_personal_info": true,
      "us_person_count": 150000,
      "data_subject_type": "consumer",
      "doj_data_category": "precise_geolocation_data",
      "precision_level": "raw",
      "is_government_related": false,
      "export_necessity": "算法训练所需训练数据"
    }
  ],
  "recipient_entities": [
    {
      "entity_name": "深度洞察人工智能有限公司",
      "country_of_registration": "China",
      "tax_id": "",
      "ownership_structure": "创始人持股60%，中国风投资本40%",
      "governing_law": "中华人民共和国法律",
      "government_control": false,
      "government_investment": "",
      "parent_company": "",
      "entity_role": "processor",
      "is_covered_person": null
    }
  ],
  "access_persons": [
```

```
{
  "person_name": "王芳",
  "nationality": "中国",
  "country_of_residence": "中国",
  "department": "AI研发部",
  "position": "机器学习工程师",
  "employer": "深度洞察人工智能有限公司",
  "has_actual_access": true,
  "access_type": "remote"
}
],
"security_measures": [
  {
    "measure_name": "logical_isolation_of_covered_data",
    "category": "access_control",
    "status": "missing",
    "description": "尚未建立隔离工作区"
  }
],
"onward_transfer": false,
"onward_transfer_description": "",
"attachments": [],
"company_name": "GeoData Analytics Inc.",
"override_thresholds": null
}
```

风险评估结论

总体红黄绿: YELLOW

是否禁止交易: 否

是否限制交易: 是

摘要: 限制性交易（整改前不得进行）：该交易属于 EO 14117 § 100.3 限制性交易类别。当前存在 21 项安全措施缺口，在全部整改完成并经法务审批前，不得继续推进数据传输。建议在 90 天内完成整改。

附件解析摘要

- 无

第1章 总体结论与传输可行性

总体结论

红黄绿判定: 黄灯 (限制性交易)

限制性交易 (整改前不得进行) : 该交易属于 EO 14117 § 100.3 限制性交易类别。当前存在 21 项安全措施缺口, 在全部整改完成并经法务审批前, 不得继续推进数据传输。建议在 90 天内完成整改。
> ⚠ 整改前不得推进数据传输。存在安全措施缺口, 在全部整改完成并经法务审批前, 不得继续推进。

传输可行性

限制性交易, 需采取措施

可条件性推进: 否

触发规则

- Restricted transaction type (vendor_agreement) involving covered person(s) and bulk sensitive personal data — requires security measures under EO 14117 § 100.3.

需补充材料

- The following 21 security measures are required but not yet implemented: logical_isolation_of_covered_data, multi_factor_authentication, least_privilege_access, role_based_access_control, encryption_at_rest.... Please provide implementation timeline and responsible parties.

第2章 风险详情与分析

风险详情与分析

涵盖人员/实体清单

已确认涵盖人员:

- 深度洞察人工智能有限公司 (置信度: 90%): Registered in country of concern: China (中国); Governed by law of country of concern: 中华人民共和国法律 (中国); Access person '王芳' resides in country of concern (中国, 中国) and has actual data access.

敏感数据分布

- 精确GPS轨迹数据: precise_geolocation_data, US persons: 150000, 阈值: 1000, 命中: 是

风险匹配矩阵

- 深度洞察人工智能有限公司 [confirmed] × 精确GPS轨迹数据 → YELLOW (Restricted transaction type (vendor_agreement) involving covered person(s) and bulk sensitive personal data — requires security measures under EO 14117 § 100.3.)

第3章 合规措施建议与行动清单

合规措施建议与行动清单

⚠ 黄灯 (整改前禁止推进)

在以下安全措施全部整改完成前, 不得继续推进数据传输。

必要安全措施状态

- 缺失: logical_isolation_of_covered_data
- 缺失: multi_factor_authentication
- 缺失: least_privilege_access
- 缺失: role_based_access_control
- 缺失: encryption_at_rest

- 缺失: encryption_in_transit
- 缺失: key_management
- 缺失: data_aggregation
- 缺失: de_identification_or_pseudonymization
- 缺失: purpose_limitation_controls
- 缺失: comprehensive_activity_logs
- 缺失: log_retention_minimum_1_year
- 缺失: real_time_alerting
- 缺失: independent_audit_quarterly
- 缺失: employee_training_program
- 缺失: confidentiality_agreements
- 缺失: background_checks
- 缺失: onward_transfer_restrictions
- 缺失: data_deletion_on_termination
- 缺失: audit_rights_clause
- 缺失: breach_notification_clause

缺失措施 (21项): logical_isolation_of_covered_data, multi_factor_authentication, least_privilege_access, role_based_access_control, encryption_at_rest, encryption_in_transit, key_management, data_aggregation, de_identification_or_pseudonymization, purpose_limitation_controls, comprehensive_activity_logs, log_retention_minimum_1_year, real_time_alerting, independent_audit_quarterly, employee_training_program, confidentiality_agreements, background_checks, onward_transfer_restrictions, data_deletion_on_termination, audit_rights_clause, breach_notification_clause

建议90天内完成整改，整改完成后重新提交评估。

第4章 附件与持续监控

附件与持续监控

附件清单

(详见输出包中的 rule_engine_result.json、facts.json、evidence_chain.json)

⚠ 需补充材料

- The following 21 security measures are required but not yet implemented: logical_isolation_of_covered_data, multi_factor_authentication, least_privilege_access, role_based_access_control, encryption_at_rest.... Please provide implementation timeline and responsible parties.

持续监控建议

- 季度复审接收方实体状态
- 监控 EO 14117 法规更新
- 定期审计安全措施有效性
- 更新数据清单和人数统计
- 接收方变更、数据类别新增、交易结构调整时触发重新评估